



Instituto Politécnico Nacional
Escuela Superior de Cómputo
Ingeniería en Sistemas Computacionales



“IT GOVERNANCE”

“Análisis de riesgos”

Hernández Aranda Hector Alejandro

Lagarza Ortega Ana Karen

Márquez Rodríguez Gael Alejandro

Trejo Hernández Brandon

7CV4

ROCIO PALACIOS SOLANO

ACTIVO			VALORACIÓN						
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	Área Geográfica	Periodo de Afectación	IMPACTO	Cantidad de Infraestructuras Críticas Afectadas	Campos Afectados	INTERDEPEN-DENCIA	CRITICIDAD
OMNIS_P1	OMNIS_P1_BD	Base de datos relacional	2	1	2	2	1	2	IV
	OMNIS_P1_USR	Gestión de perfiles de usuario	2	1	2	1	1	2	III
	OMNIS_P1_USR	Catálogo segmentado (cache)	1	1	1	1	1	1	I
OMNIS_P2	OMNIS_P2_PAG	Microservicio de pagos	2	1	3	1	2	3	IV
	OMNIS_P2_TRX	Registro propiedad permanente	1	1	2	1	2	2	III
	OMNIS_P2_NTF	Sistema de notificaciones de pago	1	1	1	1	1	1	I
OMNIS_P3	OMNIS_P3_EVAL	BD evaluaciones y quizzes	1	1	2	1	1	1	II
	OMNIS_P3_STR	Plataforma streaming HD (Blob + CDN)	2	1	3	2	2	3	IV
	OMNIS_P3_CRT	Emisión de certificados digitales	1	1	2	1	2	2	III

IDENTIFICACIÓN DE INFRAESTRUCTURAS CRÍTICAS		
INFRAESTRUCTURAS CRÍTICAS DETECTADAS	GRADO DE CRITICIDAD	CONTROLES A IMPLEMENTAR
Base de datos relacional	Crítica	AES-256, backups RPO≤24h RTO<4h, HA multi-zona, firewall BD
Microservicio de pagos	Crítica	Tokenización PCI-DSS, TLS 1.3, alertas fraude, auditoría mensual
Plataforma streaming HD (Blob + CDN	Crítica	SAS tokens, CDN multi-zona, auto- scaling, WAF
Registro propiedad permanente	Alta	Validación server-side, log inmutable, conciliación diaria
Emisión de certificados digitales	Alta	Firma SHA-256 CA, QR validación, mecanismo revocación
Gestión de perfiles de usuario	Alta	Argon2id, MFA, RBAC, logs de acceso
Sistema de notificaciones de pago	Media	Firma HMAC, canal TLS, rate-limit de envíos
Catálogo segmentado (cache)	Baja	Control de roles, versionado, auditoria, TTL firmado

AMENAZAS	EVENTO DE AMENAZA (RIESGO)	CONTROLES
Robo de credenciales, acceso no autorizado	Fuga masiva; violación LFPDPPP	Firma SHA-256 CA, QR validación, mecanismo revocación
SQLI, ransomware, fallo hardware	Pérdida permanente de progreso académico	AES-256, backups RPO≤24h RTO<4h, firewall BD
Modificación no autorizada, inyección de contenido	Desinformación académica, daño institucional	Roles, versionado, auditoria, TTL firmado
Intercepción, skimming, fraude en pasarela	Robo financiero, pérdida de confianza	Tokenización PCI-DSS, TLS 1.3, no-log, alertas
Manipulación de parámetros, acceso sin pago	Pérdida de ingresos, acceso fraudulento a bundles	Validación server-side, log inmutable, conciliación
Suplantación de notificación, phishing por confirmación falsa	Fraude por confirmación falsa, pérdida de confianza	Firma HMAC, canal TLS, rate-limit
DDoS, caída nube, acceso no autorizado al contenido	Indisponibilidad de clases, interrupción del aprendizaje	SAS tokens, CDN multi-zona, auto-scaling, WAF
Trampa en evaluaciones, manipulación de calificaciones	Certificaciones fraudulentas, pérdida de valor académico	Calificación server-side, respuestas cifradas
Falsificación, clonación de credencial académica	Fraude en contratación, daño institucional	Firma SHA-256 CA, QR validación, mecanismo revocación

ACTIVO				VALORACIÓN				TRATAMIENTO	
ID Riesgo	ID Activo	Amenaza / Vulnerabilidad	Activo Afectado	Probabilidad	Impacto	Nivel Riesgo	Riesgo Residual	Control / Tratamiento	Responsable
R01	OMNIS_P1_USR	Credenciales sin Argon2id / sin MFA	Datos personales y perfiles	Media	Alto	Alto	Medio	Argon2id (m=64MB,t=3,p=4), bloqueo tras 5 intentos, MFA, RBAC	Backend / Seguridad
R02	OMNIS_P1_BD	BD expuesta sin firewall ni cifrado en reposo	Base de datos relacional	Baja	Alto	Medio	Bajo	AES-256 en reposo, firewall BD, backups RPO≤24h RTO<4h	DevOps / DBA
R03	OMNIS_P1_CAT	Modificación no autorizada del catálogo (sin versionado)	Catálogo segmentado	Media	Medio	Medio	Bajo	Control de acceso por roles, versionado, auditoría de cambios, TTL firmado	Dev Team
R04	OMNIS_P2_PAG	Comunicación con pasarela sin tokenización PCI-DSS	Microservicio de pagos	Media	Alto	Alto	Bajo	Tokenización PCI-DSS, TLS 1.3, no-log datos sensibles, alertas de fraude	Backend / Finanzas
R05	OMNIS_P2_TRX	Asignación de propiedad ejecutable desde el cliente	Registro propiedad permanente	Baja	Alto	Medio	Bajo	Validación server-side, log inmutable de transacciones, conciliación diaria	Backend
R06	OMNIS_P2_NTF	Notificaciones de pago sin firma digital (suplantación)	Sistema de notificaciones	Media	Medio	Medio	Bajo	Firma HMAC en payload, canal TLS, rate-limit de envíos	Backend

R07	OMNIS_P3_STR	Azure Blob con URLs públicas sin SAS tokens	Plataforma streaming HD	Alta	Alto	Alto	Medio	SAS tokens con expiración, CDN multi-zona, auto-scaling, WAF	DevOps
R08	OMNIS_P3_EVAL	Validación de quiz en cliente (trampa / manipulación)	BD evaluaciones y quizzes	Media	Alto	Alto	Bajo	Calificación exclusiva en backend, respuestas cifradas en tránsito	Backend
R09	OMNIS_P3_CRT	Certificados sin firma CA confiable (falsificación)	Certificados digitales	Baja	Alto	Medio	Bajo	Firma SHA-256 con CA, QR de validación en línea, mecanismo de revocación	Backend
R10	OMNIS_P3_STR	Caída o latencia del streaming (DDoS / pico de tráfico)	Plataforma web · Blob · Nube	Media	Alto	Alto	Bajo	Auto-scaling, CDN, WAF, mitigación DDoS en < 60 min	DevOps / Seguridad

	Impacto bajo	Impacto medio	Impacto alto
Probabilidad alta	Medio	Alto	Critico R07
Probabilidad media	Bajo	Medio R03 – R06	Alto R01-R04-R08-R10
Probabilidad baja	Bajo	Bajo	Medio R02-R05-R09

ACTIVO			VALORACIÓN						IDENTIFICACIÓN IC				
ID Proceso	ID Activo	Activo de Información	Área Geo	Período	Impacto	IC Afect.	Campos	Interdep.	Criticidad	IC Detectada	Controles	Grado	Responsable
OMNIS_P1	OMNIS_P1_BD	Base de datos relacional	2	2	3	2	2	3	IV	BD de usuarios y progreso	AES-256, backups RPO≤24h RTO<4h, HA multi-zona, firewall BD	Crítica	DevOps/DBA
OMNIS_P2	OMNIS_P2_PAG	Microservicio de pagos	2	1	3	1	2	2	IV	Procesamiento de transacciones	Tokenización PCI-DSS, TLS 1.3, alertas fraude, auditoría mensual	Crítica	Finanzas/Backend
OMNIS_P3	OMNIS_P3_STR	Plataforma streaming HD (Blob + CDN)	2	2	3	2	2	3	IV	Azure Blob / streaming de cursos	SAS tokens, CDN multi-zona, auto-scaling, WAF	Crítica	DevOps
OMNIS_P2	OMNIS_P2_TRX	Registro propiedad permanente (bundles)	1	1	2	1	2	2	III	Acceso a contenido adquirido	Validación server-side, log inmutable, conciliación diaria	Alta	Backend
OMNIS_P3	OMNIS_P3_CRT	Emisión de certificados digitales	1	1	2	1	2	2	III	Acreditación académica digital	Firma SHA-256 CA, QR validación, mecanismo revocación	Alta	Backend
OMNIS_P1	OMNIS_P1_USR	Gestión de perfiles de usuario	2	1	2	1	1	2	III	Autenticación y perfiles	Argon2id, MFA, RBAC, logs de acceso	Alta	Backend/Seguridad

OMNIS_P3	OMNIS_P3_EVAL	BD evaluaciones y quizzes	1	1	2	1	1	1	II	Progreso y calificaciones	Calificación server-side, respuestas cifradas en tránsito	Media	Backend
OMNIS_P2	OMNIS_P2_NTF	Sistema de notificaciones de pago	1	1	1	1	1	1	II	Confirmación de transacciones	Firma HMAC, canal TLS, rate-limit	Media	Backend
OMNIS_P1	OMNIS_P1_CAT	Catálogo segmentado (caché + frontend)	1	1	1	1	1	1	I	Catálogo de cursos y paquetes	Control de roles, versionado, auditoría, TTL firmado	Baja	Dev Team